

AWS IAM Misconfiguration & Least-Privilege Hardening Lab

By: Chontele Coleman

Date: 01/20/2026

Executive Summary

This project demonstrates the identification and remediation of common AWS Identity and Access Management (IAM) misconfigurations that can lead to full cloud account compromise. The lab intentionally began with an insecure administrative configuration, analyzed the associated risks, and implemented least-privilege access controls, multi-factor authentication (MFA), and centralized logging using AWS CloudTrail. Validation was performed by attempting unauthorized actions and confirming denied events were logged.

The goal of this project was not to deploy production workloads, but to showcase practical cloud security decision-making, access control hardening, and detection capabilities aligned with SOC, GRC, and IT Support roles.

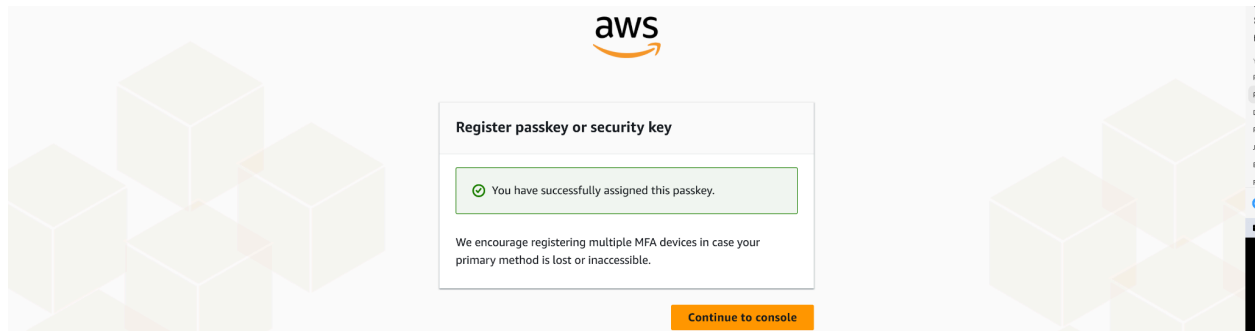
Objectives

Demonstrate a real-world IAM misconfiguration scenario to assess the security risk of excessive permissions. Implement least-privilege access using IAM groups and policies. Enforce MFA for privilege access also to enable and validate logging and detection using AWS CloudTrail. Lastly to document scope, limitations, future enhancements.

Environment Overview

- AWS Free Tier account
- IAM Users, Groups, and Policies
- AWS CloudTrail (management events)
- Optional EC2 (t2.micro) for permission validation
- Local lab (VirtualBox VMs) used only for console access; no hybrid integration

Root account with MFA enabled with no access keys present:



Threat Model

Assets

- AWS account and all associated resources
- IAM users, roles, and policies
- CloudTrail logs
- EC2 and other cloud services protected by IAM

Adversaries

- External attacker who compromises IAM credentials
- Malicious or negligent insider with excessive permissions
- Automated credential abuse via leaked passwords

Threats

- Full account takeover via AdministratorAccess
- Unauthorized creation or deletion of cloud resources
- Disabling of logging to evade detection
- Persistence through IAM backdoors

Security Controls Implemented

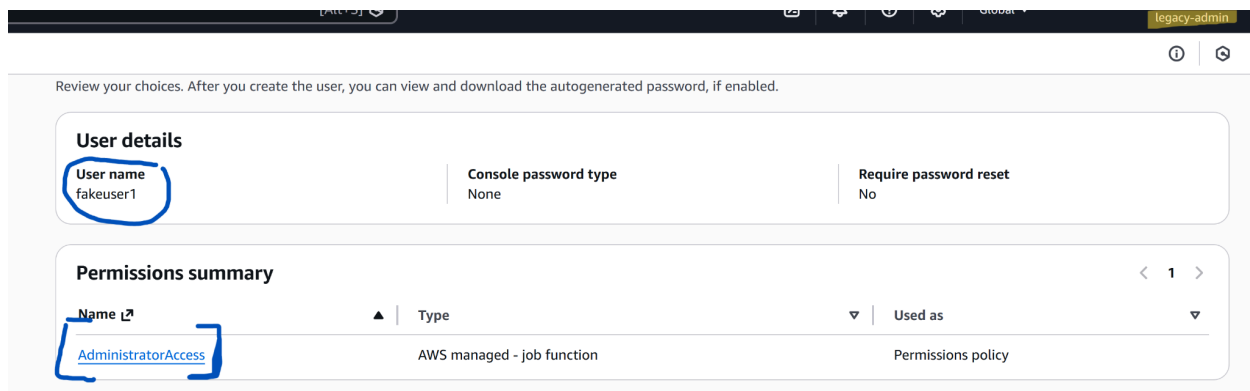
- Removal of direct administrative permissions
- Least-privilege group-based access
- Mandatory MFA for non-root users
- CloudTrail logging for all management events

Initial Insecure Configuration

Misconfiguration Identified

- IAM user **legacy-admin** was created with:
 - Directly attached **AdministratorAccess** policy
 - Console access without MFA

legacy-admin with AdministratorAccess policy able to create users and change policies:



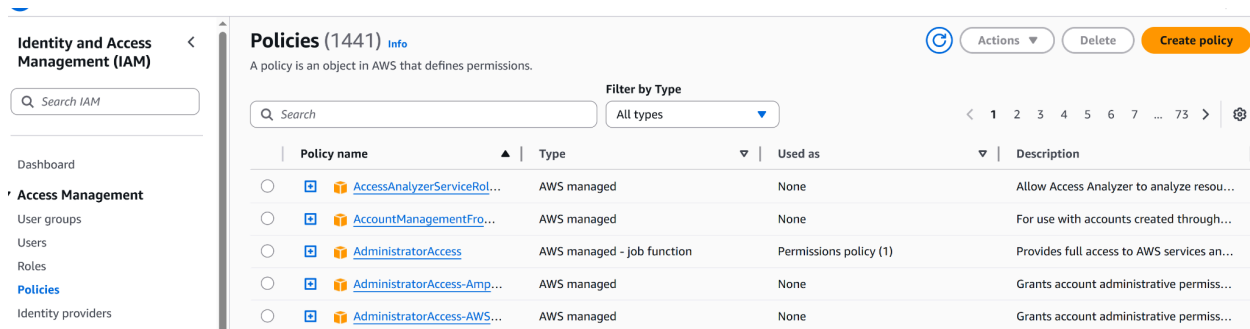
Review your choices. After you create the user, you can view and download the autogenerated password, if enabled.

User details

User name fakeuser1	Console password type None	Require password reset No
------------------------	-------------------------------	------------------------------

Permissions summary

Name ↗	Type	Used as
AdministratorAccess	AWS managed - job function	Permissions policy



Identity and Access Management (IAM)

Search IAM

Dashboard

Access Management

- User groups
- Users
- Roles
- Policies**
- Identity providers

Policies (1441) Info

A policy is an object in AWS that defines permissions.

Filter by Type: All types

Policy name	Type	Used as	Description
AccessAnalyzerServiceRol...	AWS managed	None	Allow Access Analyzer to analyze resou...
AccountManagementFro...	AWS managed	None	For use with accounts created through...
AdministratorAccess	AWS managed - job function	Permissions policy (1)	Provides full access to AWS services an...
AdministratorAccess-Amp...	AWS managed	None	Grants account administrative permis...
AdministratorAccess-AWS...	AWS managed	None	Grants account administrative permis...

Risk Analysis

This configuration violates the principle of least privilege and introduces a single point of failure. If the credentials are compromised, an attacker gains unrestricted control over the AWS account, including the ability to disable logging and create persistence mechanisms.

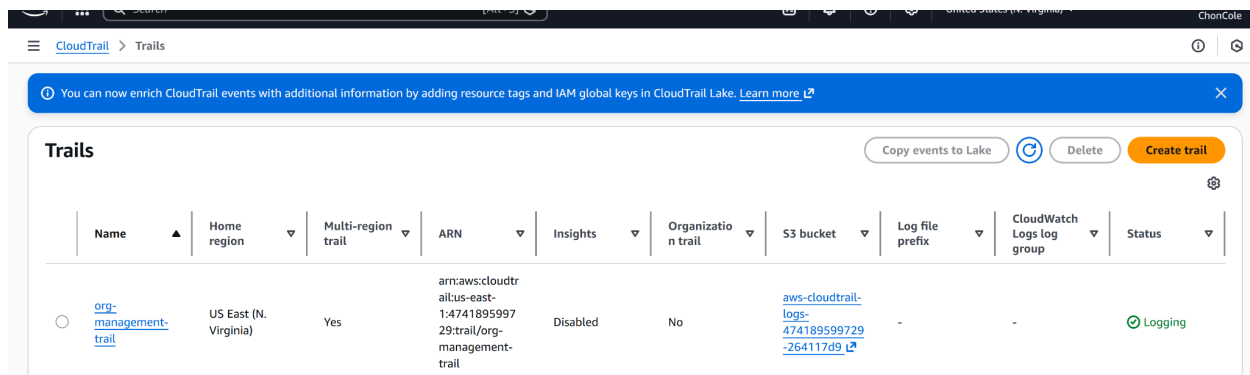
Detection Enablement

CloudTrail Configuration

- Multi-region trail enabled
- Management events (read/write) logged
- Centralized logging for IAM and EC2 actions

CloudTrail ensures that all administrative actions are recorded and can be reviewed during incident response or audits.

CloudTrail configured to log all mgmt. events across regions for centralized detection and auditability:



The screenshot shows the AWS CloudTrail Trails console. At the top, there's a blue banner with a message: "You can now enrich CloudTrail events with additional information by adding resource tags and IAM global keys in CloudTrail Lake. [Learn more](#)". Below this, the "Trails" section is visible. It includes buttons for "Copy events to Lake", "Delete", and "Create trail". A table lists the configured trails. The table has columns: Name, Home region, Multi-region trail, ARN, Insights, Organization trail, S3 bucket, Log file prefix, CloudWatch Logs log group, and Status. One trail is listed: "org-management-trail" in the "US East (N. Virginia)" region, with "Multi-region trail" set to "Yes". Its ARN is "arn:aws:cloudtrail:us-east-1:474189599729:trail/org-management-trail", Insights are "Disabled", and it is not an organization trail. The S3 bucket is "aws-cloudtrail-logs-474189599729-264117d9" and the log file prefix is "-". The CloudWatch Logs log group is "-", and the status is "Logging".

Name	Home region	Multi-region trail	ARN	Insights	Organization trail	S3 bucket	Log file prefix	CloudWatch Logs log group	Status
org-management-trail	US East (N. Virginia)	Yes	arn:aws:cloudtrail:us-east-1:474189599729:trail/org-management-trail	Disabled	No	aws-cloudtrail-logs-474189599729-264117d9	-	-	Logging

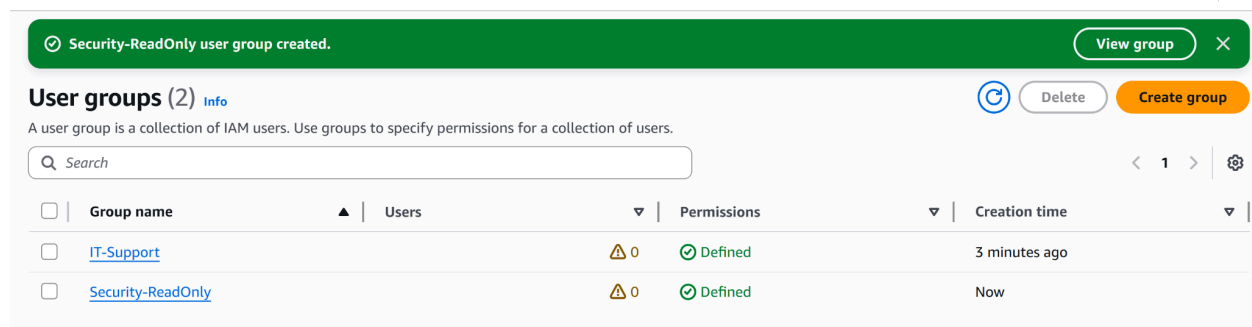
Remediation and Hardening

IAM Group Design

Two IAM groups were created:

- **IT-Support**
 - Read-only access to EC2, S3, and CloudWatch
 - No write or administrative permissions
- **Security-ReadOnly**
 - AWS managed **SecurityAudit** policy

Role-based IAM group design enforcing least-privilege access without direct user policy attachments:

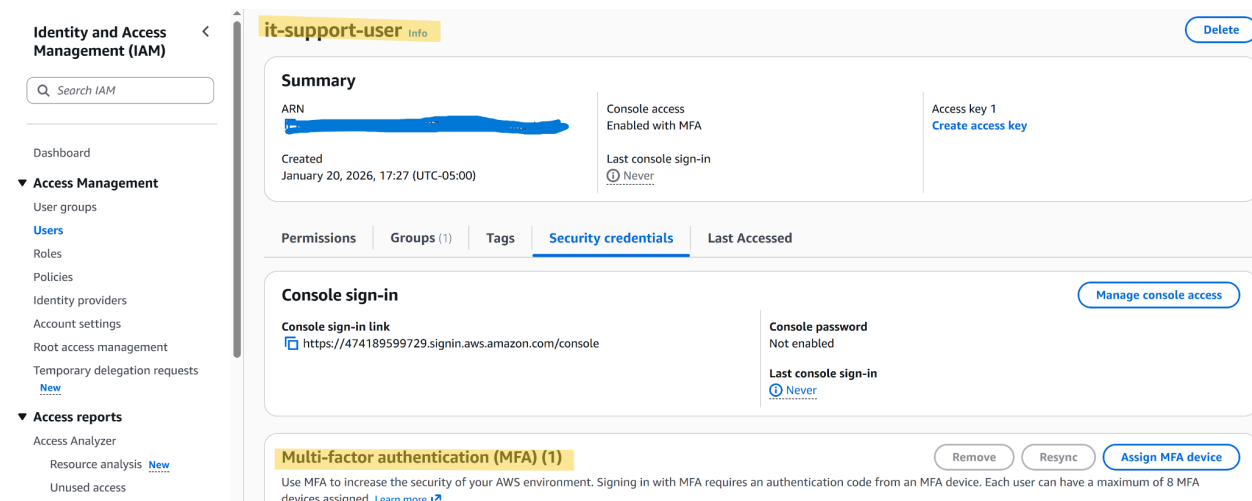


Hardened User Configuration

- User: `it-support-user`
- Permissions granted via group membership only
- MFA enabled
- No direct policies attached

This approach enforces role-based access control and prevents privilege creep.

MFA enforced for non-root IAM user to reduce credential compromise risk:



Validation & Testing

The `it-support-user` account was used to validate access controls by attempting actions outside its assigned permissions:

- Attempted EC2 instance creation – denied
- Attempted IAM modifications – denied
- Attempted logging changes – denied

Denied actions were successfully recorded in CloudTrail as **AccessDenied** events, confirming both preventive and detective controls were functioning as intended.

Once EC2 write actions were confirmed to be denied, additional destructive testing (such as stopping or terminating instances) was considered redundant and out of scope.

CloudTrail logs showing AccessDenied events when a least-privileged user attempted unauthorized EC2 and IAM actions:

ry > ListDelegatedAdministrators ⓘ

ListDelegatedAdministrators Info

Details Info

Event time
January 20, 2026, 18:03:27 (UTC-05:00)

User name
it-support-user

Event name
ListDelegatedAdministrators

Event source
organizations.amazonaws.com

AWS access key
[REDACTED]

Source IP address
[REDACTED]

Event ID
c5c56841-adcf-4079-9d84-4901d377d868

Request ID
4fe19a42-bacb-4b2e-9e10-6e162cb8d3e3

AWS region
us-east-1

Error code
AccessDenied

Read-only
true

Scope & Limitations

This lab focused specifically on IAM misconfigurations, privilege management, and logging validation. Network-level controls, application security, and data exposure scenarios were intentionally excluded to maintain a focused assessment.

Future Enhancements

Potential extensions of this lab include:

- S3 public exposure misconfiguration and remediation
- Multi-service IAM policy testing across EC2, S3, and Lambda
- Integration with AWS Config or Security Hub for automated detection

These enhancements were documented but not implemented to preserve scope clarity.

Skills Demonstrated

- AWS IAM administration
- Least-privilege access design
- Threat modeling
- Cloud logging and detection
- Security risk assessment and remediation
- Professional security documentation

Conclusion

This project demonstrates how common IAM misconfigurations can expose an AWS environment to significant risk and how structured remediation, logging, and validation can reduce the attack surface. The lab mirrors real-world cloud security assessments by emphasizing scope definition, risk-based decision-making, and evidence-driven validation rather than exhaustive but redundant testing.